

Incident Response Report

Zenith Tech Ransomware Incident — IR Activity 1.0 and IR Activity 2.0

Table of Contents

Table of Contents	2
Part 1 – Incident Response Actions Taken.....	3
The Zenith Tech Ransomware Incident Response Report is Lab 01 – IR Activity 1.0.	3
Part 1 – Incident Response Actions Taken	3
Description.....	3
Preparation	3
Observations.....	3
Incident Summary	3
Action Timeline	5
Phase 1 – Preparation: what was being done	7
Phase 2 - Identification	7
Phase 3 – Containment.....	7
Phase 4 – Eradication: Removal and Confirmation	7
Phase 5 – Recovery.....	7
Phase 6 – Post-Incident Analysis	8
Phase 7 – Communication	8
Phase 8 – Legal and Compliance	8
Reflection.....	8
References.....	9
PART 2: IR Activity 2.0: Hands-On Exercise: Assemble Your Cybersecurity Response Team.....	9
Introduction	9
1. The Zenith Tech Incident Response Team	9
Incident Response Manager	9
Security Analyst	10
IT Specialist.....	10
Legal/Compliance Officer	10
Communication Officer	10
2. How the Response Unfolds.....	10
3. How Roles Depend on Each Other	11
4. Challenges in Coordinating the Team	11
5. Summary of Each Role's Contribution	12
6. Recovery and Lessons Learned	12
Conclusion.....	12
Reflection.....	13
References	13

Part 1 – Incident Response Actions Taken

The Zenith Tech Ransomware Incident Response Report is Lab 01 – IR Activity 1.0.

Part 1 – Incident Response Actions Taken

Description

IR Activity 1.0 had our group discuss generally how to deal with every stage of an incident. We will be looking at the Zenith Tech scenario as if it were a real incident and detailing our personal response as the on-call Cybersecurity Analysts. This will be a departure from a generic “team response” in that we will describe what we did in each phase, with specific tools, commands and decisions recorded. This amount of detail is appropriate for a real post of incident report, for internal review or regulatory purposes.

The Office of the Superintendent of Financial Institutions' (OSFI, 2025) instructions on reporting a technology or cyber incident were used as a structure for the incident documentation, with the aim of capturing all required fields for a regulated organization. The incident-handling lifecycle from the National Institute of Standards and Technology (Cichonski et al., 2012) is used as an organizational structure and broke down to four steps: preparation; detection and analysis; containment, eradication, and recovery; and post-incident activity. This report provides more detail than the general description of team actions on specific actions, when they were taken, and outlining the results of our actions.

Preparation

We implemented some measures before the incident that were necessary in case of an incident. This involved an incident response runbook with contact details for escalation, EDR (Endpoint Detection and Response) agents on all workstations and servers (Microsoft Defender for Endpoint in this instance) and regular, immutable and offline backups of customers' databases and files. We also had a forensic USB toolkit (FTK Imager/Magnet RAM Capture) and had access to local administrative and network devices to not get slowed down during an incident. The SIEM had alert rules that would alert if there was any mass renaming of files or unusual outbound traffic, which was what this incident response was triggered by.

Observations

Incident Summary

The incident details are provided in Table 1-1, which is updated to reflect that the incident has been resolved and to document the action(s) we took as opposed to a hypothetical in-progress response.

Incident information	
Institution	Zenith Tech
Incident name or identifier	ZT-INC-2024-0315-0900
Incident report type	Post-incident report
Incident status	Resolved: operations restored to normal
Date, time and time	2024-03-15, approx. 0840 (Eastern Time)

zone the incident occurred	
Date, time and time zone the incident was detected	2024-03-15, 0900 (Eastern Time)
Site location and lines of business affected	
Where did the incident occur?	Zenith Tech-IT owned infrastructure
Third-party, subcontractor, or other details	Not applicable
Business line and service identification	Customer service, IT operations, corporate communications
Geographic site or locale affected	Zenith Tech's head office, Waterloo, Ontario, Canada.
Technology assets affected	Customer data store, internal communication systems, endpoint workstation ZT-WKS01 (patient zero, critical asset)
Incident details	
Incident category	Cyber incident
Incident type	Malware or ransomware
Incident result	Compromise (attempted data exposure), but contained before encryption completed
Incident severity or priority	Severity 1/Critical
Incident description	At 9:00 AM, an alert was raised from the SIEM system about strange outbound traffic and extensive renaming of files on one workstation, which was caused by the phishing email that was received at 8:40 AM. Eight minutes later, the incident was brought under control, without any confirmed information about the data leak. Cleanup and recovery operations were concluded at 12:22 PM.
Breach of RTO/RPO	No: it was restored within internal RTO of 4 hours; RPO breach avoided using immutable backups
Activation of BCP/DRP	Not activated: degraded-mode workarounds were sufficient; full BCP/DRP was not required because the 3-hour 42-minute recovery window
Impact scope – Service delivery	Moderate: customer service and internal messaging degraded for approximately 2 hours
Impact scope – Sensitive information	Low: customer data store was reachable from the compromised host, but no exfiltration was confirmed
Impact scope – Media or public sentiment	None identified: incident was contained before any public or media awareness
Estimated financial impact or financial risk (CAD)	No ransom was paid
Estimated number of impacted users, clients, or transactions	1 workstation directly compromised; ~40 customer-service staff experienced brief degraded access; no customer accounts confirmed affected
Estimated recovery timeframe	NA: incident fully resolved (see Incident duration)
Incident duration	3 hours, 42 minutes (08:40 compromise to 12:22 full recovery)
Incident recurrence	None: no related prior incidents identified in Zenith Tech's incident history

Incident root cause	Phishing email providing first payload (human mistake/insufficient email filtering mechanism)
Cyber threat actor details	
Threat-actor tactics, techniques, and procedures (TTP)	Obtaining access via phishing email that had infected macro files, establishment of persistence through using scheduled tasks and registry, and file renaming operation considered preparation for ransomware attack.
Indicators of compromise (IoC)	The domain name of malicious sender and email hash (blocked); external C2 IP address and domain (blocked by firewall); malware hash (added to threat intelligence summary); suspicious outbound traffic from computer ZT-WKS01.
Internal and external notifications	
Senior management notification	Yes — notified 2024-03-15, 0930 (Eastern Time)
Other regulatory or supervisory notification	OSFI Technology Risk Division — report generated to be submitted within a 24-hour period (see Phase 8)
Law enforcement or security agency notification	Not involved — incident contained, and there is no distress signal from the criminal part that would require engagement
Cyber insurance notification or claim submission	The service provider was informed, but no claim was made because the financial impact was less than the deductible.

Table 1-1. Post-incident summary for the Zenith Tech incident, structured on the OSFI (2025) incident information, incident details, and RTO/RPO fields, reflecting the incident as resolved.

Action Timeline

Table 1-2 lists the precise, timestamped actions we undertook during the response

Time	Phase	Action I took	Tool / command
09:00	Identification	A SIEM alert for unusual outbound traffic and a surge in file rename activities was received on ZT-WKS01. The alert was acknowledged, and triaging commenced.	SIEM console
09:04	Identification	A The host's authentication and endpoint logs for the past hour were examined, and no log entries were found that indicated that the destination IP was added to the allow list. The hash value of the file rename and process was checked against the threat intelligence feed.	SIEM log search; VirusTotal hash lookup
09:09	Identification	The internal severity rating system was used to assign the incident level of 1/Critical. The incident commander and on call IT person were notified.	Internal severity matrix; phone/Teams escalation
09:12	Containment	The switch port for ZT-WKS01 was disabled to immediately isolate it from network traffic and the entire VLAN for finance and customer service was moved to quarantine until more indepth analysis could be performed.	switchport access vlan 999 / shutdown on the access port
09:15	Containment	The active directory user account was compromised and disabled, then a new	Disable-ADAccount; klist purge

		Kerberos ticket was issued to reset all sessions of this user account.	
09:19	Containment	The server's external C2 IP and the linking domain were blocked from the firewall before other actions were taken on the endpoint to cut the outbound signal completely without waiting for the reaction to the compromise.	Firewall deny rule (outbound, destination IP/FQDN)
09:25	Containment	Made a complete memory image and forensic disk image of the workstation before working with it further for evidence retention ahead of removal.	Magnet RAM Capture; FTK Imager
09:40	Eradication	Found the malware from the hash and behavior of the collected sample, confirmed there was no need for public decryption as the process was not completed, and erased the malicious scheduled task and registry run key for persistence.	EDR isolation console; sc delete; reg delete
09:55	Eradication	Tracked down the entry vector to a phishing email received at 08:40, which contained a project with macros. Deleted the email and all its copies from mailboxes and added the sending domain to the email blocking policy of the gateway.	Mail-flow search and purge; email gateway block list
10:10	Eradication	Re-imaged ZT-WKS01 from a nice-clean host image rather than a manually clean system, and launched a full EDR scan on every endpoint of the affected VLAN to confirm no lateral movement.	Imaging deployment tool; EDR full-environment scan
10:30	Eradication	Rotated the credentials for the compromised account and any service account having a user logged to the compromised host and required all users to authenticate using MFA.	AD bulk password reset; Entra MFA enforcement
10:45	Recovery	Restored the customer data store from the immutable backup from that night, and validated row counts and checksums against the baseline prior to the incident.	Backup restore console; checksum validation script
11:15	Recovery	Re-established the internal messaging system and removed the quarantine VLAN block from the finance/customer service segment after the EDR confirmed that the scan was clean.	EDR dashboard; VLAN reconfiguration
12:22	Recovery	Confirmed with the Business Continuity Planner that all business activities were proceeding normally, thus officially closing the active incident report and achieving the objective for recovery time.	Internal status call / sign-off
13:00	Communication	Prepared internal notice for all staff to explain briefly about what took place, and checked the external message with the Communications Officer and Legal Advisor before dispatching it.	Internal comms template; joint review
13:30	Legal/Compliance	Notified senior management about incident and provided the report with the Legal Advisor confirming that the incident is of	Notification log; OSFI report template

		reportable nature under applicable regulations and preparing the initial OSFI-styled report using the form in Table 1-1 for the purpose of reporting within 24 hours.	
Day +2	Post-Incident Analysis	Reviewed actions taken, created the timeline presented above, established that the reason for the incident was the phishing email, and initiated two more tickets, tightening the email attachment sandboxing policy and adding the confirmed indicators of compromise to our threat intelligence.	After-action review; ticketing system

Table 1-2. Timestamped action log for the Zenith Tech incident, showing the specific tool or command used for each action across all eight activity phases.

Phase 1 – Preparation: what was being done

The preparatory work done before the incident happened (correct configuration of SIEM alerts, having EDR on all endpoints, securing immutable offline backups and a toolkit for forensic investigation) was key in the discovery of the situation at 9 a.m. and its containment at 9:12 a.m. We could immediately close a switch port and disable an Active Directory account, without having to go through a lengthy approval process during the incident.

Phase 2 - Identification

It was not only strange traffic that we were able to detect. Rather, we received a specific correlation alert from the SIEM indicating that outbound traffic reached a critical point, and that files from a particular host were being renamed—a standard operation in a case of ransomware-based attack. The first thing that had to be done was to collect authentication and endpoint logs for that machine and try to make a timeline, at the same time verifying the hashes of the process in the threat intelligence feed to determine if it was a known threat or if it was an innocent process. This evaluation is only after that evaluation that we were able to classify the incident and escalate it.

Phase 3 – Containment

Our containment plan was well thought out in a logical manner, to minimize the spread of the virus and to hold onto evidence. We began by isolating the one confirmed host at the port switch level, and thus affecting no users who were not already affected. We then deleted the compromised account from Active Directory and reset the Kerberos ticket of the compromised account, to prevent any other device from escaping to another. Next, we blocked the command-and-control IP and domain of the malicious actor and blocked any outbound communication using the firewall. The extent of the network was confirmed after imaging the host, and the restriction was expanded as a precaution to the entire VLAN.

Phase 4 – Eradication: Removal and Confirmation

We did not just delete files from the live machine but identified the malware type based on the image and removed the dedicated persistence mechanisms. We then traced the infection back to a phishing email sent 20 minutes prior to the encryption and banned the malware sender. After cleanup, we imaged the host from a known-clean image because we did not trust cleaning processes and initiated the EDR scan on all the devices of the VLAN before closing the case. All user and service account credentials that had accessed the host were rotated.

Phase 5 – Recovery

The first item to be restored was the customer data store, which is the most important business function. The previous nights unused backups were used to restore the system. Due to the checks, the checksum and the number of rows were checked before returning the product into the operational environment. Next, the internal messaging system was restored, with monitoring. No connectivity was present on the VLAN until the EDR performed a clean sweep. We monitored a 4-hour internal recovery time objective (ITE) and checked the Business Continuity Planner to see that the functions of business were operating correctly, before closing the Incident window at 12:22, approximately 3 hours and 42 minutes after the incident.

Phase 6 – Post-Incident Analysis

After two days, we held the after-action review and reviewed the process of the incident in the timeline as outlined in Table 1-2. It was confirmed that the incident was caused by a phishing e-mail. I'm going to try to start two specific follow up items rather than a more generic "improve security awareness". This included asking for a modification of the macro-attachment sandboxing rule for the email gateway and adding the confirmed indicators of compromise (IOCs) including the sender's domain, the malware hash and the C2 IP address to the threat intelligence feed.

Phase 7 – Communication

I gave a briefing to staff in an internal staff notice that condensed the facts and reminded them to be careful, but at the same time not giving away technical information that could be used to replicate the incident. The External notification to the customers was consulted with Communications Officer and Legal Advisor before it was released to avoid any action being taken on its own. Recorded the time of contact with the senior management, as required by OSFI (OSFI, 2025), and made sure that no outside questions were asked other than by the official spokesperson.

Phase 8 – Legal and Compliance

The team consulted with the Legal Advisor to ensure that the incident meets our reporting criteria. We started developing a technology and cybersecurity report using the format provided in Table 1-1 and prepared for it to be submitted to OSFI within 24 hours (OSFI, 2025). Since the encryption was not complete, no data left our environment. We decided not to let anyone know about the incident for PIPEDA purposes; however, we kept a record of our decision and reasoning for future reference.

Reflection

One thing we knew for certain about this response was that we would only attempt larger VLAN containment once we had the switch port of the verified host shut down (09:12), had the user account suspended (09:15), and blocked the C&C IP address (09:19), as this would limit the impact of the incident and ensure that the forensic image captured after the incident was not contaminated by the C2 server.

The preservation of the evidence was priceless in the 09:40-10:10 eradication window, and it helped us determine the entry point as the phishing email received at 08:40 and not what we could guess it would have been at. This enabled them to take firm decisions, such as removing the message and blocking the domain, which was sending the phishing e-mail message, rather than a blanket message to the staff. Communication and legal steps after that, such as logging the management report and confirming the PIPEDA decision with Legal took a similar amount of time as technical containment of the breach which served as a reminder that the speed of the response to the breach is determined not by the speed of the technical response but by the slowest administrative step.

In the end, the two tickets opened during Phase 6 of the post-incident review: tightening of attachment sandboxing as well as adding confirmed indicators of compromise to the threat-intelligence feed, are what make the report truly effective.

References

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). Computer Security Incident Handling Guide (NIST Special Publication 800-61, Rev. 2). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>

Office of the Superintendent of Financial Institutions. (2025, January 15). OSFI technology and cyber incident report – Detailed instructions. Government of Canada.

PART 2: IR Activity 2.0: Hands-On Exercise: Assemble Your Cybersecurity Response Team

Introduction

Most people picture a cyberattack as a lone analyst staring at a screen full of alerts. In practice, the technical problem is only one part of it. While engineers work on the attack, someone must decide priorities, someone must answer customers, and someone must ask whether the company owes anyone a notification. If nobody knows who what does, the first hour is spent on confusion instead of response. This exercise puts Zenith Tech in that situation. A Distributed Denial-of-Service (DDoS) attack is flooding one of its critical applications, the customer portal, with traffic, and legitimate users are struggling to get in. Zenith Tech responds with a five-person incident response team. Each person has a defined job, but the value comes from how they work together, which matches NIST guidance on coordinated detection, response, recovery, and communication (Nelson, Rekhi, Souppaya, & Scarfone, 2025).

1. The Zenith Tech Incident Response Team

The team consists of an Incident Response Manager, a Security Analyst, an IT Specialist, a Legal/Compliance Officer, and a Communication Officer.

Incident Response Manager

The manager is the person who keeps the response from turning five people by giving five different orders. Their first job is to confirm that this is a real incident rather than a bad day for the network, and to judge how badly the portal is affected. After that, they set priorities, assign work, and decide when something needs to be escalated.

The manager does not need to be the best technician in the room. What matters is weighing the analyst's rough picture against business impact and making a call without perfect information. They also act as the single contact for senior leadership, protecting the team from constant "any update?" Interruptions.

Security Analyst

The analyst answers the question everyone else depends on: what is actually happening? They work through monitoring dashboards, firewalls, load balancer logs, and application logs, looking for the shape of the traffic. Is it thousands of scattered addresses or a few sources? Does it target the login page or the whole site?

The analyst also must stay skeptical. A DDoS attack can be a distraction while someone attempts something quieter, such as probing credentials or exploiting vulnerability elsewhere. So, the analyst reports what they have confirmed, what they only suspect, and what they do not know yet. NIST describes incident handlers as responsible for verifying incidents, analyzing information, prioritizing response activities, and limiting damage (Nelson, Rekhi, Souppaya, & Scarfone, 2025), and this role carries most of that load.

IT Specialist

The IT Specialist owns the infrastructure and the practical work of keeping the portal reachable. Typical options include tightening rate limits, blocking abusive address ranges, moving traffic through a DDoS scrubbing or content delivery service, scaling up capacity, and calling the Internet service provider or cloud provider to filter traffic upstream.

None of these options are free. Aggressive rate limiting can lock out real customers, and extra capacity costs money and may only postpone the problem. The specialist explains these trade-offs plainly and reports quickly when something is not working.

Legal/Compliance Officer

At first glance a DDoS attack looks like a pure availability problem, so a lawyer may seem out of place on the team. The reason is uncertainty. Early in an incident, nobody knows for sure whether customer data is involved, whether the attack is connected to an extortion demand, or whether Zenith Tech's contracts promise customers a certain level of uptime or a certain notice period.

The officer works alongside the analyst to establish the facts before drawing conclusions. They track whether any reporting or notification duties apply, review what the company is contractually committed to, and advise on what can be safely said outside the company. NIST stresses coordinating reporting and communication with internal and external stakeholders where laws, regulations, or policies require it (Nelson, Rekhi, Souppaya, & Scarfone, 2025).

Communication Officer

During an outage, silence is read as either incompetence or concealment. The Communication Officer makes sure Zenith Tech speaks with one voice. They draft the internal message, so employees and the customer support desk know what to tell callers, update the public status page, and prepare customer notices.

They do not invent technical details. Everything they publish comes from verified findings and has been approved by the manager and the Legal/Compliance Officer.

2. How the Response Unfolds

Suppose it is a Tuesday morning. At about 9:40 a.m., the customer support desk starts getting calls that the portal is timing out. A few minutes later, monitoring alerts showed a sharp jump in inbound traffic and a rising error rate on the web servers.

The Security Analyst looks at the logs and sees that requests are arriving from a huge spread of addresses, all hammering the same few pages. That pattern fits a DDoS attack rather than a busy day or a failed software update. By 9:55, the analyst has told the Incident Response Manager, who opens an incident channel, calls the team together, and sets the priorities: keep the portal available to real customers, understand the scope, limit the damage, communicate accurately, and preserve evidence. The IT Specialist starts with the quickest measures, temporary rate limits and blocking the most obvious sources, and contacts the cloud provider about traffic filtering. Twenty minutes later, the analyst reports that the traffic has shifted to different addresses. The first measures helped a little, but the attackers adapted. They agree to route traffic through a scrubbing service, which takes longer to set up but lasts. Meanwhile, the Legal/Compliance Officer asks a simple question: is there any sign that anything other than availability is affected? The analyst checks authentication logs and database activity and finds nothing unusual so far but says this is a preliminary finding and will be checked again. The officer confirms no notification of duty applies yet and reminds the team to keep records. The Communication Officer posts a short status page notice saying that some customers may have trouble accessing the portal and that the team is working on it. An hour later, when the scrubbing service is in place and the error rate begins to fall, an updated notice goes out after approval by the manager and legal. The team is not moving in a straight line. Information changes, measures fail, and the plan gets adjusted, which fits NIST's picture of response as an ongoing cycle involving many people with different responsibilities (Nelson, Rekhi, Souppaya, & Scarfone, 2025).

3. How Roles Depend on Each Other

The roles function as a chain of information. The analyst's findings shape what the IT Specialist does. The specialist's results tell the manager whether the plan is working. The manager's decisions determine what the Communication Officer can say, and the Legal/Compliance Officer reviews those statements, so they are accurate and safe.

Take the moment the analyst finds that the attack is aimed at the login and payment pages. The manager can tell the specialist to protect those pages first. The Communication Officer can warn customers that checkout may be slow instead of announcing a general outage, and the Legal/Compliance Officer can check whether any payment-related contractual commitments are affected. One piece of technical information changes what four other people do.

The same holds in reverse. If support hears customers describing a specific error message, that detail goes back to the analyst and specialist and might help their diagnosis. Passing information back and forth is what makes them a team rather than a list of job titles (Nelson, Rekhi, Souppaya, & Scarfone, 2025).

4. Challenges in Coordinating the Team

The most obvious challenge is time pressure. Every minute of downtime costs the company's revenue and trust, and that pressure pushes people toward hasty decisions.

Incomplete information is hard. During the first hour, nobody knows how big the attack is, how long it will last, or who is behind it. The team must act on partial facts and be willing to change courses.

Communication can go wrong in several ways. Executives want firm answers, and customers want a restoration time, but the technical team may have neither. A well-meaning employee might tell a caller, "It'll be over soon," a promise nobody can keep. This is why one designated voice matters.

Finally, there is disagreement. The IT Specialist might want to take a vulnerable feature offline to protect the rest of the system, while the business wants it to run because it brings revenue. The manager's job is

to hear both, weigh the risks, and plan that everyone will follow even if they would have chosen differently.

Predefined roles and a clear chain of authorities do not remove these difficulties, but they do prevent time from being wasted on questions like "who decides this?" (Nelson, Rekhi, Souppaya, & Scarfone, 2025).

5. Summary of Each Role's Contribution

Role	Main Contribution During the DDoS Attack
Incident Response Manager	Sets priorities, assigns tasks, makes decisions, and keeps senior management informed.
Security Analyst	Identifies and analyzes the attack, watches for related activity, and reports verified findings.
IT Specialist	Applies and adjusts technical mitigation to keep the portal available.
Legal/Compliance Officer	Assesses legal, contractual, and privacy obligations and reviews external statements.
Communication Officer	Delivers consistent, approved updates to employees, customers, and other stakeholders.

6. Recovery and Lessons Learned

When traffic returns to normal, the work is not finished. The team first confirms that the portal is stable and that the mitigation measures can be safely kept in place or unwound. The analyst also double-checks that nothing else happened during the attack.

A few days later, the manager holds a review while the details are still fresh. Useful questions include:

- How long did it take to notice the attack, and why?
- Which mitigation steps helped, and which wasted time?
- Did everyone know who was in charge and what they were responsible for?
- Were customer messages timely, accurate, and consistent?
- Do we need better monitoring, a standing agreement with a scrubbing provider, or a rehearsed playbook?

The purpose is improvement, not blame. NIST's guidance treats lessons learned as an input to better cybersecurity risk management and future response (Nelson, Rekhi, Souppaya, & Scarfone, 2025)

Conclusion

The Zenith Tech scenario shows that incident response is as much about coordination as technology. Stopping a DDoS attack requires technical skill, but limiting its damage also requires leadership, honest communication, and attention to legal duties. The manager keeps the response coherent, the analyst supplies facts, the IT Specialist acts on them, the Legal/Compliance Officer guards against avoidable risk, and the Communication Officer keeps stakeholders informed.

Reflection

Before this exercise, I assumed the Security Analyst was the central figure in any cyber incident, because that is the role most people associate with cybersecurity. Working through the scenario changed that view. The analyst is critical, but an analyst who finds the attack and has nobody to coordinate, mitigate, communicate, and assess obligations has solved only a small part of the problem.

What stood out to me most was how much of the response depends on ordinary human skills: communicating clearly, admitting uncertainty, and deciding when information is good enough to act on. That is hard to practice during an incident, so rehearsing roles in advance seems valuable.

It also made me appreciate how easy it would be to overreact or underreact. Treating every DDoS attack as a data breach could cause unnecessary panic and legal exposure, but ignoring the possibility that it is a cover for something else could be a serious mistake. The disciplined approach is to verify, document, and update the picture as new information arrives.

I came away thinking that a strong incident response team is not one where everyone knows everything. It is one where everyone knows their own job, trusts others to do theirs, and communicates enough for the whole team to act as one.

References

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST Special Publication 800-61 Rev. 3). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r3>